

CISCO SECURE WORKLOAD

PCI DSS v4.0 Compliance Framework

Payment Card Industry Data Security Standard

Prepared for: [Customer Name]

Prepared by: Cisco Systems, Inc.

Date: [Month Year] | Version 1.0 | Cisco Confidential

Regulatory Standard: PCI DSS v4.0 (March 2022)

Environment: Hybrid (On-Premises + Cloud)

Deployment Stage: Fresh Installation

How to read the coverage words

Full Coverage on the older reports means Secure Workload can produce that row's artifact. It does not mean the control is met.
Partial Coverage means file that export next to another control.
Evidence Required means Secure Workload has no record. The customer files the contract, the analysis, or the HR or physical-security evidence.
Direct, Supporting, and Out of scope on the newer reports are the same idea in different words. Direct is still evidence, not a pass.

Executive Summary

PCI DSS v4.0 introduces the Customized Approach and strengthens network segmentation requirements significantly. Cisco Secure Workload (CSW) directly satisfies Requirements 1 (Network Security Controls), 6 (Vulnerability Management), 7 (Access Control), 10 (Logging & Monitoring), and 11 (Security Testing) — the five requirements most commonly cited in PCI DSS audit findings.

CSW's workload-level micro-segmentation provides stronger CDE isolation than traditional firewall-only approaches, directly addressing QSA concerns about lateral movement within the cardholder data environment.

Control Coverage Summary

Re q	Sub-Req	Control	PCI DSS Requirement	CSW Implementation	Coverage
Re q 1	1.2.1	Network Control Config	Document and enforce network security controls	ADM generates complete approved flow documentation; policy workspace serves as config evidence	Full Coverage
Re q 1	1.3.1	Inbound CDE Traffic	Restrict inbound traffic to CDE to only what is necessary	Default-deny inbound to CDE scope; explicit allowlist only	Full Coverage
Re q 1	1.3.2	Outbound CDE Traffic	Restrict outbound traffic from CDE to only what is necessary	Block direct internet from CDE; allowlist-only outbound paths	Full Coverage
Re q 1	1.4.1	CDE Network Controls	Controls between CDE and untrusted networks	Workload-level micro-segmentation; enforced at OS — not just perimeter	Full Coverage
Re q 6	6.3.3	Vulnerability Remediation	Protect all system components from known vulnerabilities	Continuous CVE scanning; CVSS-ranked remediation; compensating controls	Full Coverage
Re q 7	7.2.1	Access Restriction	Restrict access to system components and cardholder data	Scope-based allowlist policies; process-level access audit per workload	Full Coverage
Re	10.2.1	Audit Log	Capture required	Full 5-tuple flow + process +	Full Coverage

q 10		Events	audit log events	user context logging on all CDE workloads	
Re q 10	10.3.1	Audit Log Protection	Protect audit logs from destruction and unauthorized modification	Tamper-resistant cluster storage; export to immutable SIEM	Full Coverage
Re q 10	10.4.1	Audit Log Review	Review audit logs daily	Dashboard summary + automated alert export eliminates manual review burden	Full Coverage
Re q 11	11.3.1	Vulnerability Scans	Perform vulnerability scans at least quarterly	Continuous scanning exceeds quarterly requirement; reports serve as evidence	Full Coverage
Re q 11	11.4.1	Penetration Testing	Implement penetration testing methodology	ADM baseline used as pre/post-pentest reference; forensic telemetry captures all pentest activity	Partial Coverage
Re q 12	12.3.2	Targeted Risk Analysis	Conduct targeted risk analysis for customized implementations	CSW vulnerability + ADM data feeds targeted risk analysis documentation	Evidence Required

Cardholder Data Environment (CDE) Architecture

Recommended Scope Segmentation

CSW organizes workloads into scopes that directly map to PCI DSS network segmentation requirements:

CDE (Strictest)	CDE-Connected	Out-of-Scope	Third-Party Processors
PAN Storage Payment Processing Payment Gateways HSM Servers	Web Servers Auth Servers Logging Infrastructure	Corporate Systems Dev/Test Environments HR Systems	PCI-Compliant Vendors Acquirers Processing Networks
Default DENY all inbound Allowlist-only outbound Full forensic logging	Restricted to CDE-approved flows ADM-validated policies	Zero CDE communication ADM confirms isolation	BAA-documented paths Full flow audit per processor

QSA Evidence Package

Evidence Item	CSW Source	PCI Requirement	Frequency
CDE network policy export	Defend → Policy Workspaces	Req 1	Per assessment
CDE inbound/outbound flow log	Investigate → Flow Search	Req 1, Req 10	Continuous
Policy violation report	Alerts → Triggered Events	Req 10	Monthly
Vulnerability scan report (CDE)	Investigate → Vulnerability	Req 6, Req 11	Weekly
CDE scope membership snapshot	Inventory → Export	Req 1, Req 7	Monthly
Anomaly detection log	Alerts → Dashboard	Req 10, Req 11	Monthly
ADM dependency map (CDE)	Investigate → ADM	Req 1	Quarterly
Process audit log (CDE)	Investigate → Process Search	Req 10	On-demand